CHAPTER D5

Governance, safety, and risk management

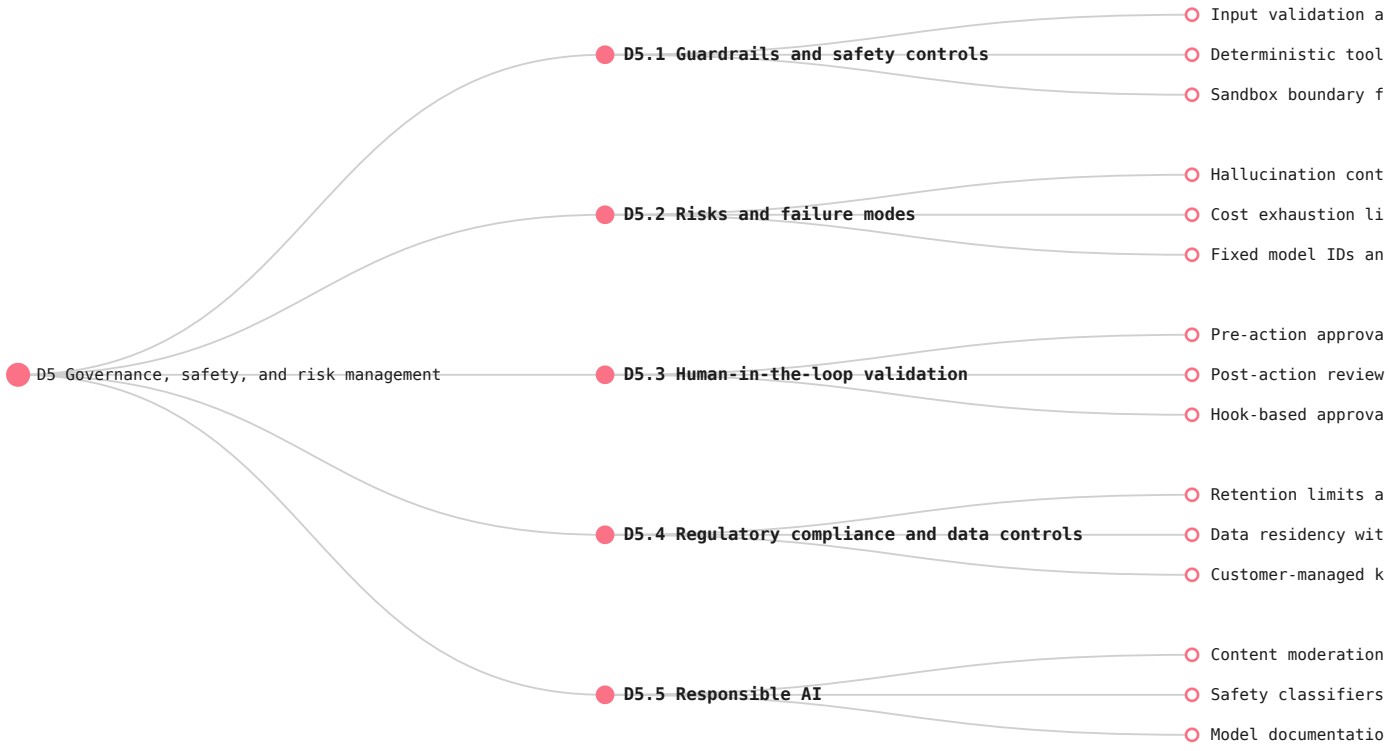
WEIGHT 14%. INFERENCE FROM SECONDARY SOURCES.

Enforce in code, approve the irreversible, confirm coverage.

5 sections, 15 components, 15 recall cues.

CONCEPT MAP

Units branch to components. On a small screen, scroll sideways.



SECTIONS

D5.1 CHAPTER D5, GOVERNANCE, SAFETY, AND RISK MANAGEMENT

Guardrails and safety controls

Screen untrusted text. Enforce authorization in code.

CONSTRAINT FAMILIES



INPUT VALIDATION AND UNTRUSTED-CONTENT HANDLING

A prompt is guidance. Code checks user input and labels third-party content before the model acts on it.

Rule Screen untrusted text before the main call, and keep third-party content in tool_result blocks.

Trap A stricter system prompt as the only control. The model can still follow an injected instruction, and no code stops the action.

Exam tip If the only defense is prompt wording, add an input screen or a code check.

DETERMINISTIC TOOL AUTHORIZATION GATE

Code that runs the tool decides whether the call proceeds, so the model cannot override the decision.

Rule Enforce each limit for a tool with side effects in code, before the call runs.

Trap A longer prompt that says the model must not call the tool. The model can still propose the call, and only code blocks it.

Exam tip If a system prompt sentence is the only check on a limit, the design needs a code gate.

SANDBOX BOUNDARY FOR SHELL COMMANDS

A boundary enforced by the host limits what a shell command can reach, even when injected content steers the command.

Rule Use the sandbox for shell commands, and use permission rules for file and web tools.

Trap A team turns the sandbox on and believes it covers file tools or hooks. The sandbox wraps shell commands only.

Exam tip If the scenario asks about the Read tool, the sandbox does not apply to that tool.

▼ RECALL CUES (3)

1. **a model follows a prompt sentence that forbids a limited action**
   Answer code gate on the tool call
   Rule Enforce the limit in code. Keep the prompt sentence as guidance only.
   - Longer system prompt with more warnings
   - Remove the tool and lose the function
2. **instructions appear inside a document that the agent reads**
   Answer untrusted-content handling plus a tool gate
   Rule Label and screen the content. Keep the gate on every tool the content could steer.
   - Trust a document because the company stored it
   - Allow all tools for convenience
3. **a shell command could read credentials or reach an unknown host**
   Answer sandbox boundary with an empty allowed domain list
   Rule Limit shell reach by default. Add hosts and paths only when a task needs them.
   - Add every host to avoid prompts
   - Assume the sandbox covers file tools

▼ NUMBERS AND VERSIONS (3)

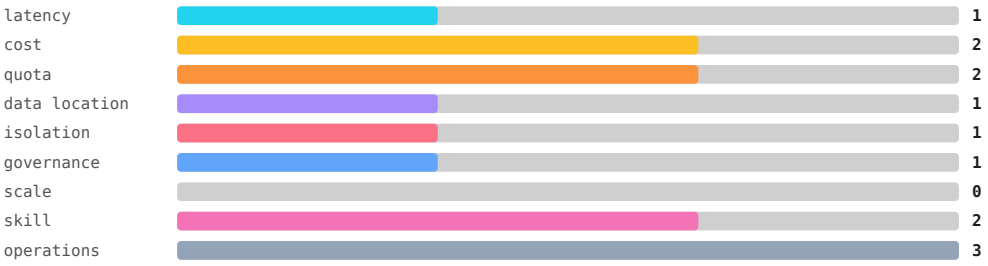
- Claude Haiku 5.5 runs safety classifiers that can decline the screen request itself. source
- A PreToolUse hook that exits with code 2 blocks the tool call. source
- The sandbox runs on macOS, Linux, and WSL2. source

D5.2 CHAPTER D5, GOVERNANCE, SAFETY, AND RISK MANAGEMENT

Risks and failure modes

Every claim needs a source quote, or it goes.

CONSTRAINT FAMILIES



HALLUCINATION CONTROL WITH GROUNDED QUOTES

A claim that cites a quote from the source is checkable, and a claim without a quote is removed.

Rule Require a source quote for each claim, and remove each claim that has none.

Trap A larger model looks like the fix for unsupported claims. The docs describe quotes, permission to abstain, and citations for the same risk.

Exam tip If the scenario asks for a control on unsupported claims, choose quotes and citations over a model change.

COST EXHAUSTION LIMITS

A spend limit on a workspace caps the monthly loss, and a call cap in code stops one runaway run.

Rule Set a monthly spend limit on each workspace, and cap the calls per run in code.

Trap A higher rate limit looks like a fix for a cost problem. It allows more calls, so it raises spend.

Exam tip If the scenario names the Default Workspace, remember that you cannot set a spend limit on it.

FIXED MODEL IDS AND RETIREMENT

A pinned model ID keeps behavior fixed, and a tested migration plan handles the retirement date.

Rule Pin a model ID for each release, and move to a tested replacement before retirement.

Trap An earlier alias is wrongly taken as a fixed version. A 4.6-generation ID is a snapshot, but an earlier alias points to the latest snapshot for its minor version.

Exam tip If the scenario asks how to avoid silent change, choose the pinned ID and a replacement test.

▼ RECALL CUES (3)

1. **a loop drives spend up overnight**
   Answer spend limit and call cap
   Rule Cap spend per workspace. Cap tool calls per run in code.
   - Longer timeout
   - Higher rate limit
2. **an answer states a fact that no source supports**
   Answer quote grounding with removal of unsupported claims
   Rule Require a quote for each claim. Remove each claim that has none.
   - Larger model alone
   - Longer prompt with more warnings
3. **a model reaches retirement while traffic continues**
   Answer pinned ID and tested replacement
   Rule Track usage by model. Move to an active ID before the retirement date.
   - Alias that moves to a newer snapshot
   - Wait for failed requests before a move

▼ NUMBERS AND VERSIONS (7)

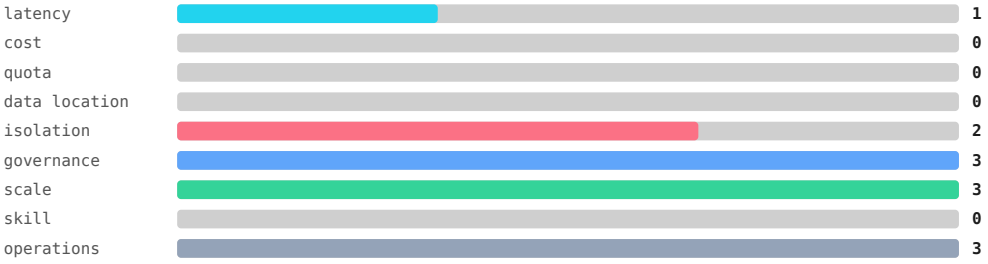
- For long documents above 20k tokens, ask Claude for word-for-word quotes before the task. source
- The Amazon Bedrock default quota is 2 million input tokens per minute. source
- Customers can request up to 5 million input tokens per minute without additional Anthropic approval on Amazon Bedrock. source
- When usage reaches a workspace spend limit, requests return HTTP 400 with invalid_request_error until the next month or a change to the limit. source
- On Claude Platform on AWS, spend can take about 2 hours to reflect recent usage, and the overshoot is billed. source
- Anthropic gives at least 60 days notice before retirement for publicly released models. source
- A dateless model ID from the 4.6 generation is a fixed snapshot. source

D5.3 CHAPTER D5, GOVERNANCE, SAFETY, AND RISK MANAGEMENT

Human-in-the-loop validation

Irreversible action: approve before. Reversible: review after.

CONSTRAINT FAMILIES



PRE-ACTION APPROVAL FOR IRREVERSIBLE ACTIONS

A person approves an action before it runs when the action cannot be undone.

Rule Use pre-action approval when the action cannot be undone.

Trap Approval on every action, even at high volume, which stalls the queue. The stakes decide the review shape.

Exam tip If the scenario gives a volume and a cost per review, compare the review load before you choose a shape.

POST-ACTION REVIEW AND MONITORING

A reviewer checks what ran after the fact, and a tested rollback path undoes a reversible action.

Rule Review reversible actions after they run, and keep a tested undo path.

Trap Post-action review presented as protection for an irreversible action. The review runs after the harm.

Exam tip If the scenario says the action cannot be undone, choose pre-action approval.

HOOK-BASED APPROVAL POINT IN CLAUDE CODE

A PreToolUse hook runs code before a tool call, so a team can add a custom check that the rules cannot express.

Rule Block in a PreToolUse hook with exit code 2, or with permissionDecision deny, when a custom check fails.

Trap A hook that prints a plain warning and exits 0 blocks nothing. To block, exit with code 2 or return permissionDecision deny in JSON.

Exam tip If a hook prints a plain warning and exits 0, expect the call to continue.

▼ RECALL CUES (3)

1. **an action removes records and cannot be undone**
   Answer pre-action approval with full context
   Rule Hold the action until a reviewer approves. Show the arguments and the policy.
   - Post-action sampling only
   - Approval on every low-risk action
2. **a high-volume reversible workflow needs oversight**
   Answer sampled or post-action review with rollback
   Rule Review a random sample after the action. Keep a tested undo path.
   - Manual review of every action
   - No review at all
3. **a team needs a check that a permission rule cannot express**
   Answer PreToolUse hook that exits with code 2
   Rule Exit with code 2, or return permissionDecision deny, in the hook when the check fails.
   - Plain text warning with exit 0
   - Longer system prompt reminder

▼ NUMBERS AND VERSIONS (5)

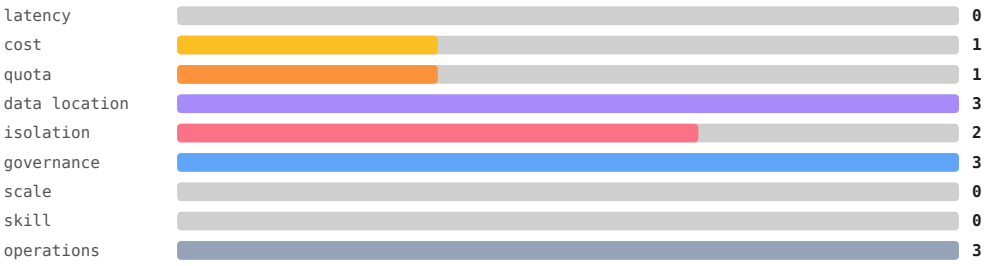
- Anthropic recommends a rolling retention of at least 30 days for Amazon Bedrock activity logs. source
- A PreToolUse hook that exits with code 2 prevents the tool call. source
- A permissionDecision of allow does not let an action through after an exit code 2 block. source
- Exit code 0 with no JSON decision means the normal permission flow applies. source
- The default timeout for a command hook is 600 seconds. source

D5.4 CHAPTER D5, GOVERNANCE, SAFETY, AND RISK MANAGEMENT

Regulatory compliance and data controls

ZDR per organization. Check feature coverage before regulated data.

CONSTRAINT FAMILIES



RETENTION LIMITS AND ZERO DATA RETENTION

The retention arrangement decides how long Anthropic keeps prompts and responses, so it is a design input and not a policy note.

Rule Enable ZDR per organization, and confirm feature coverage before regulated data reaches the API.

Trap A team believes ZDR covers every product in the account. The Console, Managed Agents, and claude.ai chat sit outside ZDR.

Exam tip If the scenario names protected health information, check HIPAA readiness before you choose ZDR.

DATA RESIDENCY WITH INFERENCE GEO AND WORKSPACE GEO

The request sets where inference runs, and the workspace sets where stored data lives, so each setting controls a different location.

Rule Set inference_geo on each request, and set allowed_inference_geos on the workspace.

Trap A region setting on the application server. The inference_geo setting controls where inference runs, not where the app runs.

Exam tip If the response shows the global geo for a US-only need, the request lacked the setting.

CUSTOMER-MANAGED KEYS AND AUDIT EVIDENCE

A customer key limits who can read new stored data, and the activity feed gives evidence of who accessed what.

Rule Use CMEK for control of new writes, and use the Compliance API for audit evidence.

Trap A team believes CMEK re-encrypts old data. It protects data written after the key takes effect.

Exam tip If the scenario asks about data written before the key took effect, state that Anthropic keys still protect that data.

▼ RECALL CUES (3)

1. **regulated data must not persist after the response**
   Answer ZDR on a ZDR-enabled organization with covered features
   Rule Enable ZDR per organization. Check feature coverage before you send data.
   - Privacy notice in the app
   - Encryption alone
2. **inference must run in one country**
   Answer per-request geo plus workspace allowed geos
   Rule Set the geo on each request and restrict the workspace to that geo.
   - Region of the application server
   - Global default with a policy document
3. **the customer must control the keys and prove access**
   Answer CMEK on a new workspace plus Compliance API evidence
   Rule Attach the key before the first request. Read the Activity Feed with a scoped key.
   - A team believes CMEK re-encrypts old data
   - Admin API key to export chat content

▼ NUMBERS AND VERSIONS (5)

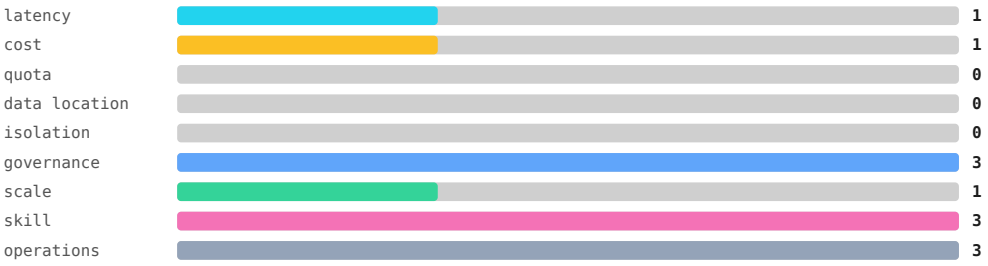
- Covered Models require 30-day data retention and are not available under ZDR unless Anthropic authorizes them. source
- US-only inference is priced at 1.1 times the standard rate across all token categories. source
- The inference_geo parameter returns a 400 error on Claude models before the 4.6 generation. source
- The Activity Feed retains events for 6 years. source
- Activities are queryable within 1 minute of their creation. source

D5.5 CHAPTER D5, GOVERNANCE, SAFETY, AND RISK MANAGEMENT

Responsible AI

Policy and examples in the prompt. A schema constrains the verdict.

CONSTRAINT FAMILIES



CONTENT MODERATION WITH CLAUDE

Claude classifies user content against a written policy and labeled examples, so the policy text is the control.

Rule Put the moderation policy and examples in the prompt, and constrain the verdict with a schema.

Trap A custom classifier looks cheaper, but each policy change then needs new labels and code. (Inference)

Exam tip If the scenario says the policy changes often, choose a prompt-defined policy over a retrained model.

SAFETY CLASSIFIERS AND REFUSAL HANDLING

A refusal is a normal response with a stop reason, so the application reads the stop reason and handles the refusal in code.

Rule Read stop_reason on every response, and handle refusal as a normal outcome.

Trap A refusal treated as an HTTP error and retried unchanged. A refusal returns a normal response with a stop reason.

Exam tip If a response has stop_reason refusal, do not parse it as an error.

MODEL DOCUMENTATION, TRANSPARENCY, AND PER-GROUP EVALUATION

Published model documentation gives context, and the team adds its own per-group evidence for its own users.

Rule Cite the system card for the model, and add a per-group evaluation for the product.

Trap A team cites the model card as proof that the product is fair. The card describes model tests, not the product's users. (Inference)

Exam tip If the answer relies only on vendor documentation, add the team's own evaluation.

▼ RECALL CUES (3)

1. **a content policy changes often and covers several languages**
   Answer prompt-defined policy with examples and a schema verdict
   Rule Keep the policy in the prompt with examples. Constrain the verdict to a schema.
   - Custom classifier retrained for each change
   - Keyword list only
2. **a classifier declines the request and the flow breaks**
   Answer stop-reason handling with fallback
   Rule Read stop_reason on every response. Handle refusal as a normal outcome.
   - Treat refusal as a server error and resend the same request
   - Remove the built-in safety classifiers from the product
3. **an overall score looks good but one group performs poorly**
   Answer per-group evaluation with a floor
   Rule Check each group against its own floor before release. (Inference)
   - Average score only
   - Generated reasons that the trace does not support

▼ NUMBERS AND VERSIONS (4)

- The moderation guide names Claude Haiku 5.5 as a cost-effective choice for large volumes. source
- Claude Fable 5.1, Claude Fable 5, Claude Opus 5.5, Claude Opus 5, Claude Sonnet 5.5, and Claude Haiku 5.5 include these classifiers. source
- Claude Haiku 5.5 has neither server-side fallback nor fallback credit, so use the SDK middleware or a manual retry. source
- The resources page links system cards for Claude Haiku 5.5, Claude Sonnet 5.5, and Claude Opus 5.5. source